

AMAZONTECH — Diretoria de Tecnologia da Informacao

PROJETO TECNICO

Proposta de Politica de Hardening para Ambiente Linux Corporativo

Ambiente: DB-01 — Servidor de Banco de Dados PostgreSQL

Equipe consultora: Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato

Curso: Windows e Linux Hardening | Disciplina: Hardening Linux | Data: 06/08/2026

Sumario

- 1. Introducao
 - 2. Caracterizacao do Ambiente
 - 3. Levantamento dos Ativos
 - 4. Analise dos Riscos
 - 5. Politica Proposta de Hardening
 - 6. Ferramentas Seleccionadas
 - 7. Plano de Implantacao
 - 8. Plano Permanente de Manutencao
 - 9. Beneficios Esperados
 - 10. Limitacoes do Projeto
 - 11. Parecer Tecnico
 - 12. Conclusoes
- Referencias | Anexos | Apendice A (Matriz) | Checklist

1. Introducao

Este projeto e o produto da consultoria contratada pela AmazonTech para elaborar uma politica corporativa de Hardening Linux adaptavel a ambientes distintos do WEB-01. Ao longo da disciplina, a equipe implantou e validou no WEB-01 controles de identidade, reducao de superficie, MAC (SELinux) e manutencao continua. A Diretoria reconhece que cada tipo de servidor exige adaptacoes. A proposta a seguir define Hardening para o **DB-01 (PostgreSQL)**, reutilizando principios validados e justificando desvios em funcao da finalidade do banco de dados (dados sensiveis, disponibilidade transacional, acesso restrito a rede interna).

Objetivo geral: entregar politica tecnicamente consistente, operacionalmente viavel e alinhada as boas praticas da disciplina, servindo de referencia para futuras implantacoes.

2. Caracterizacao do Ambiente

Tipo de servidor	Banco de dados (PostgreSQL)
Hostname proposto	DB-01
Finalidade	Persistencia de dados de aplicacoes corporativas AmazonTech
Principais servicos	postgresql, sshd, rsyslog/journald, cron, UFW, Fail2Ban, AIDE
Usuarios atendidos	Aplicacoes (contas de servico), DBAs, auditores (leitura)
Disponibilidade	Alta — janelas controladas; RTO/RPO definidos com operacao
Confidencialidade	Alta — dados de negocio e eventualmente PII
Integridade	Alta — consistencia transacional e trilha de mudancas
SO recomendado	Debian 13 ou Ubuntu 24.04 LTS (padrao corporativo pos-WEB-01)

Anexo A - Cenario DB-01 (PostgreSQL)

AmazonTech | Projeto Integrador 01 | Consultoria Hardening
Cenario selecionado: DB-01 (Servidor de Banco de Dados PostgreSQL)

Finalidade: persistencia de dados corporativos (ERP/apps internas)
SO alvo: Debian 13 / Ubuntu 24.04 LTS (linha Debian)
Servico principal: postgresql (porta 5432/tcp - apenas rede interna)
Admin remoto: sshd (22/tcp) restrito a bastion/VPN
Usuarios: DBAs (grupo dba), app runtime (nologin), auditores (ro)

Requisitos CIA:
Confidencialidade: ALTA (dados sensiveis de negocio)
Integridade: ALTA (transacoes e consistencia)
Disponibilidade: ALTA (RTO/RPO definidos pela operacao)

Diferenca vs WEB-01: foco em dados em repouso/transito DB,
superficie de rede menor (sem HTTP publico), backup/PITR critico.

Figura - Anexo A - Cenario DB-01 (PostgreSQL)

3. Levantamento dos Ativos

Ativo	Importancia	Justificativa
Dados PostgreSQL (clusters/DBs)	Critica	Nucleo do negocio; impacto direto se vazados/corrompidos
Credenciais DB / roles	Critica	Comprometimento implica acesso amplo aos dados
SO e pacotes base	Alta	Base de confianca; CVEs em libs afetam o servico
Backups / WAL / PITR	Critica	Recuperacao ante ransomware, erro humano ou desastre
Canal SSH admin	Alta	Via privilegiada de administracao
Logs (PostgreSQL + SO)	Alta	Deteccao, forense e conformidade
Politicas MAC/firewall	Alta	Contecao e menor comunicacao

4. Analise dos Riscos

Risco	Impacto	Prob.	Estrategia proposta
Exposicao 5432 a Internet	Critico	Media	UFW: 5432 so rede app/VPN; sem bind publico
Credencial DBA fraca/compartilhada	Alto	Media	Contas nominais; sudo; senha/pam; MFA no bastion
SQL injection via app	Alto	Media	Role least-privilege no DB; app user != superuser
Ransomware / wipe de dados	Critico	Baixa-Media	Backup offline/offsite + PITR + teste restore
CVE em PostgreSQL/libs	Alto	Media	apt security + debsecan; janela de patch
Alteracao indevida de configs	Alto	Media	AIDE + MAC + change control
Brute-force SSH	Medio	Media	SSH harden + Fail2Ban + AllowUsers
Privilegio excessivo app/OS	Alto	Media	Grupos, sudo, nologin em contas servico

5. Politica Proposta de Hardening

A politica integra os controles validados no WEB-01, adaptados ao perfil de banco de dados. Cada subsecao traz a decisao e a justificativa tecnica.

5.1 Controle de Identidades

Decisao: grupos *dba* (admin DB/OS limitado), *dbapp* (donos de processos app no host, se houver), *dbaudit* (leitura de logs); contas nominais; conta de servico PostgreSQL com shell nologin; proibir usuarios genericos compartilhados.

Justificativa: menor privilegio e rastreabilidade (Lab 02). Em DB, segregacao DBA vs app reduz blast radius de comprometimento da aplicacao.

5.2 Controle de Privilegios

Decisao: sudo apenas para grupo dba/admin com logging; regras especificas (systemctl status postgresql, reload, backup) em vez de ALL indiscriminado; ACL apenas excepcional e temporaria em diretorios de evidencias/backup, com remocao apos uso.

Justificativa: Lab 02 demonstrou risco de sudo amplo e valor de ACL pontual.

5.3 Servicos do Sistema

Manter: postgresql, sshd, rsyslog/journald, cron, UFW, Fail2Ban, chrony/NTP, AIDE.

Desabilitar: MTA local nao necessario (exim), servicos de desktop, compartilhamento arquivo generico, containers nao usados, qualquer listener HTTP/HTTPS neste host.

Justificativa: menor funcionalidade (Lab 03); DB-01 nao e web server.

5.4 Configuracao do SSH

Politica: PermitRootLogin no; PubkeyAuthentication yes; PasswordAuthentication preferencialmente no em producao (lab pode manter senha); X11Forwarding no; MaxAuthTries 3; AllowUsers/AllowGroups restrito a admins; Banner legal.

Justificativa: canal admin e alvo primario; mesmo padrao WEB-01 (Lab 03).

5.5 Firewall

Politica: UFW default deny incoming / allow outgoing; allow 22/tcp somente de bastion/VPN; allow 5432/tcp somente de sub-rede das aplicacoes (WEB-01/app-tier); negar 5432 de qualquer outra origem.

Justificativa: menor comunicacao; DB nunca deve ser alcancavel da Internet.

5.6 Mandatory Access Control

Escolha: SELinux (Enforcing), alinhado ao padrao validado no WEB-01 (Lab 04A) e ao LSM disponivel no padrao corporativo da equipe. Politica targeted/default com dominio adequado ao PostgreSQL; restorecon apos restore de dados; semanage fcontext para paths de data/WAL/backup.

AppArmor: alternativa valida em Ubuntu puro; nao e a escolha primaria desta proposta porque a baseline AmazonTech ja operacionalizou SELinux no programa WEB-01.

Justificativa: MAC limita processo postgres mesmo apos falha de DAC/app.

5.7 Atualizacoes

Estrategia: apt update diario; security upgrades em janela semanal (criticos 24-72h); teste em homolog DB antes de producao; needrestart/avaliacao de restart do PostgreSQL; registro de evidencias (Lab 04B).

Critérios: priorizar CVEs que afetam postgresql, openssl, libc, kernel.

5.8 Gerenciamento de Vulnerabilidades

Ferramentas: debsecan (Debian/Ubuntu); consulta a security.debian.org / USN; opcional scanner de vulnerabilidades de imagem/host da organizacao.

Procedimento: triagem semanal; ticket com CVE, pacote, severidade, prazo; nem todo CVE exige patch imediato — avaliar explorabilidade e exposicao.

5.9 Auditoria

Ferramentas: Lynis (mensal + pos-mudanca); logging sudo; logs PostgreSQL (conexoes, DDL sensivel); opcional auditd para paths de data.

Meta: acompanhar Hardening Index e warnings; nao tratar HI como nota absoluta.

5.10 Integridade

Estrategia: AIDE com baseline apos hardening inicial; check semanal e apos patches; debsums mensal; investigar diffs antes de atualizar DB do AIDE (Lab 04B).

Justificativa: detecta alteracoes em binarios/configs criticos do SO e do DB.

5.11 Backup e Recuperacao

Estrategia: backups periodicos (pg_basebackup/pg_dump conforme RPO) + arquivamento WAL (PITR); copia offsite; teste de restore trimestral; criptografia em transito/repouso dos backups; acesso restrito ao storage de backup.

Justificativa: ativo critico do DB-01; Hardening sem recuperacao e incompleto para ransomware/erro humano. (Controle adicional vs WEB-01 puro.)

5.12 Documentacao

Documentos: runbook de implantacao; inventario; matriz de portas; politica sudo; procedimentos de patch/backup/restore; registro de auditorias Lynis/AIDE; este Projeto Tecnico como referencia corporativa.

Justificativa: continuidade operacional e transferencia entre equipes.

6. Ferramentas Seleccionadas

Apenas ferramentas necessarias ao DB-01 (nao e obrigatorio usar todas da disciplina).

Ferramenta	Finalidade	Justificativa
apt / security pocket	Atualizacoes	Correcao de CVEs conhecidos (Lab 04B)
debsecan	Vulnerabilidades	Visao de CVEs por pacote no Debian
UFW	Firewall host	Menor comunicacao 22/5432
Fail2Ban (sshd)	Anti brute-force	Protege admin; 5432 nao e o foco do jail
OpenSSH harden	Acesso admin	Canal privilegiado
SELinux	MAC	Contecao de processos (Lab 04A)
AIDE	Integridade	Detecta mudancas indevidas
debsums	Integridade pacotes	Complementa AIDE
Lynis	Auditoria config	Indicador continuo de hardening
rsyslog/journald	Logs	Trilha operacional/forense
pg_basebackup/WAL	Backup/PITR	Recuperacao especifica de DB

Descartado neste host: stack HTTP/Nginx como servico local; AppArmor como MAC primario (SELinux padronizado); scanners web (pertencem ao WEB-01).

7. Plano de Implantacao

Etapa	Atividade	Objetivo
1	Inventario e baseline (Lynis/AIDE inicial)	Conhecer estado antes de mudar
2	Identidades, grupos, sudo, nologin servicos	Menor privilegio
3	Desabilitar servicos nao essenciais	Menor funcionalidade
4	Hardening SSH + UFW + Fail2Ban	Proteger admin e rede
5	Instalar/configurar PostgreSQL seguro + roles	Servico alinhado a politica
6	SELinux Enforcing + fcontext data/WAL	MAC operacional
7	Backup/PITR + teste de restore	Recuperabilidade
8	Auditoria final Lynis + evidencias + Go-Live	Aceite operacional

8. Plano Permanente de Manutencao

Atualizacoes: diarias (apt update); security semanal; criticos sob demanda.

Vulnerabilidades: debsecan semanal; DSA/USN; tickets priorizados.

Auditorias: Lynis mensal; revisao de suggestions; acompanhamento do HI.

Monitoramento: logs Postgres/SSH/UFW; alertas de disco/conexoes; Fail2Ban.

Integridade: AIDE semanal; debsums mensal; investigar antes de update DB.

Evidencias: data, responsavel, ferramentas, achados, pendencias.

Revisao da politica: semestral ou apos incidente/mudanca de arquitetura.

Frequencia	Atividades DB-01
Diariamente	apt update; checar backups/WAL; alertas auth/firewall
Semanalmente	security upgrade; debsecan; AIDE check; revisar fails SSH
Mensalmente	Lynis; debsums; teste amostral de restore; revisar roles DB
Trimestralmente	restore completo em homolog; revisao de capacidade/RPO

9. Beneficios Esperados

Seguranca: menor superficie, MAC, patch continuo e segregacao de papeis.

Disponibilidade: janelas controladas, backup/PITR e menor risco de wipe.

Administracao: padrao alinhado ao WEB-01 reduz curva de aprendizado.

Conformidade: evidencias periodicas sustentam auditorias internas.

Reducao de riscos: 5432 nao publico + least privilege mitiga incidentes tipicos de DB.

10. Limitacoes do Projeto

Esta e uma proposta de politica/consultoria: nao substitui implementacao fisica do DB-01 neste repositorio. Nao cobre WAF/aplicacao (responsabilidade do tier web). Nao detalha HA multi-AZ completo (pode ser fase 2). Ferramentas comerciais de DLP/SIEM ficam fora do escopo academico, embora compativeis. O Hardening Index Lynis e indicador, nao certificacao. Adesao depende de change control e capacitacao da operacao AmazonTech.

11. Parecer Tecnico

Cliente	AmazonTech — Diretoria de TI
Objeto	Politica de Hardening DB-01 (PostgreSQL)
Consultoria	Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato
Data	06/08/2026
Recomendacao	IMPLANTAR a politica proposta

Na condicao de consultores, avaliamos que a politica e **adequada ao ambiente de banco de dados**: reutiliza a baseline corporativa do WEB-01 (identidades, SSH, firewall, MAC, patch, auditoria, integridade) e introduz controles especificos indispensaveis ao DB (restricao de 5432, roles least-privilege, backup/PITR, foco em dados).

Beneficios: reducao material de risco de exposicao e privilegio excessivo; recuperabilidade; padronizacao operacional.

Limitacoes: exige disciplina de janelas, testes de restore e gestao de CVEs; HA geografico e controles de aplicacao sao complementares.

Recomendacoes de implantacao: seguir o plano em 8 etapas; homologar patches; validar SELinux com carga Postgres; executar restore teste antes do Go-Live.

Manutencao futura: adotar o ciclo diario/semanal/mensal da Secao 8; revisar politica semestralmente; integrar evidencias ao SGSI corporativo.

Parecer final: [X] **RECOMENDADA A IMPLANTACAO** da Politica de Hardening para o DB-01.

Responsaveis: Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato

Data: 06/08/2026

12. Conclusoes

O Projeto Integrador consolidou a passagem de execucao guiada (labs) para decisao tecnica autonoma. A escolha do DB-01 demonstrou que Hardening e contextual: os mesmos principios mudam de enfase conforme o ativo. Dificuldade principal: balancear seguranca e disponibilidade em patches/restarts de banco. Decisao mais relevante: manter SELinux + firewall estrito em 5432 + backup/PITR como pilares. Politicas adaptadas por tipo de servidor sao essenciais para a AmazonTech escalar com seguranca.

Referencias

- Documentacao dos Labs AmazonTech WEB-01 (lab01–lab04b) deste repositorio.
- Debian Security — <https://www.debian.org/security/>
- PostgreSQL Documentation — Security / Backup and Restore.
- CIS Benchmarks (Linux / PostgreSQL) — referencia de boas praticas.
- Lynis / AIDE / SELinux / UFW man pages e guias oficiais.
- Materiais da disciplina Windows e Linux Hardening (Aulas 1–4).

Anexos

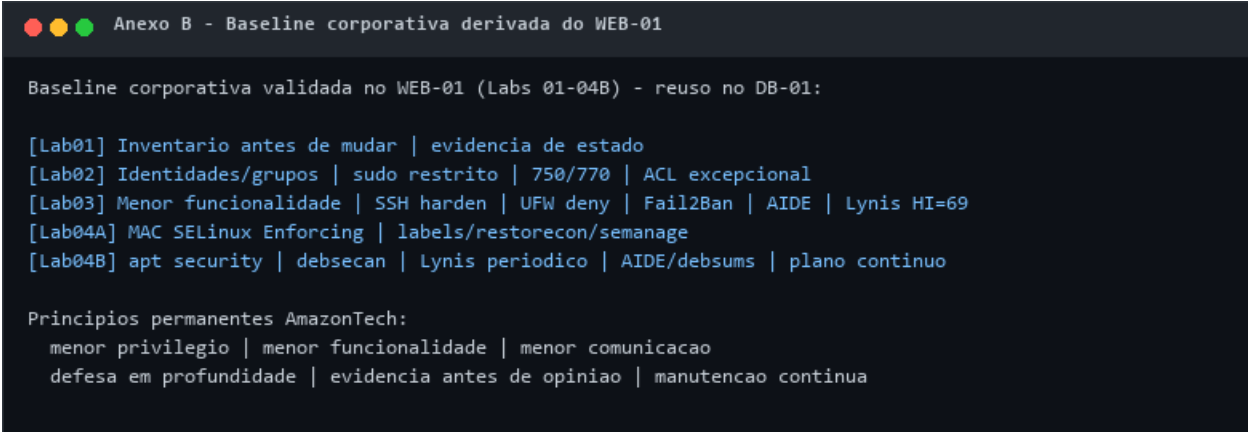


Figura - Anexo B - Baseline corporativa derivada do WEB-01

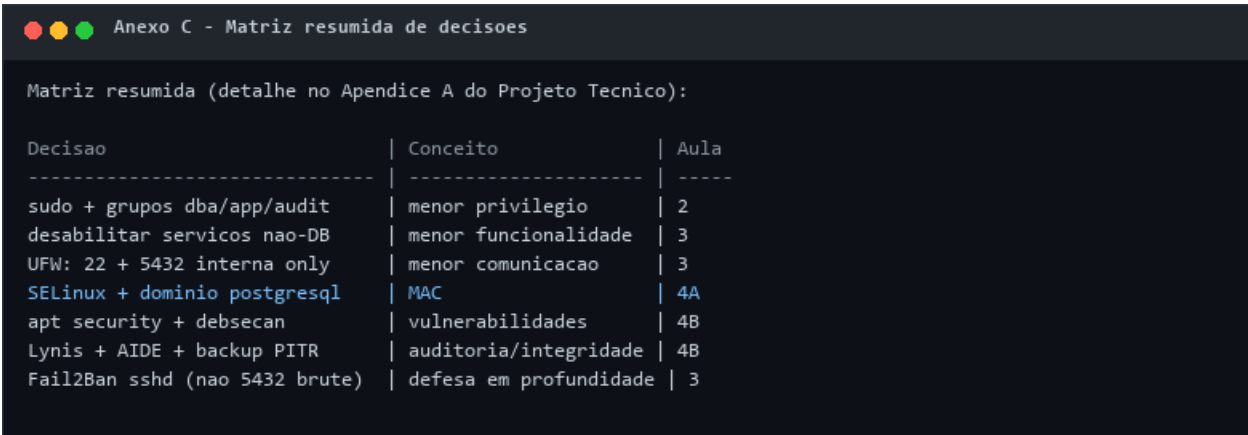


Figura - Anexo C - Matriz resumida de decisoes

Apendice A — Matriz de Justificativa das Decisoes Tecnicas

Decisao adotada	Justificativa tecnica	Aula
Grupos dba/dbapp/dbaudit + sudo restrito	Menor privilegio e segregacao de funcoes	2
Conta servico nologin	Eliminar login interativo desnecessario	2
Desabilitar MTA/HTTP no DB-01	Menor funcionalidade / superficie	3
SSH PermitRootLogin no + AllowUsers	Endurecer canal administrativo	3
UFW deny; 22 bastion; 5432 so app-tier	Menor comunicacao	3
Fail2Ban jail sshd	Resposta a brute-force	3
SELinux Enforcing + fcontext DB	Mandatory Access Control	4A
apt security + debsecan	Gestao de vulnerabilidades	4B
Lynis periodico	Auditoria continua de configuracao	4B
AIDE + debsums	Integridade de arquivos/pacotes	4B
Backup/PITR + teste restore	Disponibilidade e recuperacao (especifico DB)	4B+PI
Plano diario/semanal/mensal	Manutencao continua do Hardening	4B

Checklist Operacional de Hardening — DB-01

Atividade	Status proposta	Evidencia / referencia
Inventario e baseline	Planejado	Etapa 1 implantacao
Identidades e privilegios	Definido	Secoes 5.1–5.2
Servicos / SSH / Firewall	Definido	Secoes 5.3–5.5
MAC SELinux	Definido	Secao 5.6
Patch + vulnerabilidades	Definido	Secoes 5.7–5.8
Auditoria Lynis	Definido	Secao 5.9
Integridade AIDE/debsums	Definido	Secao 5.10
Backup/PITR testado	Definido	Secao 5.11
Documentacao e evidencias	Definido	Secao 5.12 / 8
Plano de manutencao atualizado	SIM	Secao 8